

TENRI SpA — ERP CONTABLE

Informe de Auditoría Técnica Consolidado

Branch: NSalas-dev · Fecha: 15 junio 2026 · Versión: 1.4.1

Audidores: Auditoría A (herramienta externa) + Auditoría B (análisis profundo de código fuente)

1. Resumen ejecutivo

Este informe consolida dos auditorías independientes realizadas sobre el mismo commit del branch NSalas-dev. La primera auditoría (A) fue realizada por herramienta externa el 15/06/2026 con una puntuación de 7.1/10. La segunda auditoría (B) realizó análisis profundo de código fuente sobre los mismos archivos, encontrando hallazgos adicionales especialmente en seguridad y cumplimiento normativo chileno.

La puntuación combinada se ajusta a 6.3/10 principalmente por tres bugs de seguridad críticos no detectados en la auditoría A que afectan la integridad multitenant, y por brechas de cumplimiento normativo (LRE, DJ 1887, Art. 58 CT) que exponen a los clientes a sanciones regulatorias.

1.1 Puntuación comparativa por módulo

Módulo	Auditoría anterior	Auditoría combinada	Diferencia / razón
Seguridad	9.0	6.5	-2.5 → IDOR facturas, mass assignment, SSO bypass no detectados
Calidad backend	8.0	7.5	-0.5 → TODO P1 activo, PPM hardcodeada, tope Art.58 CT ausente
Migraciones / modelos	8.0	7.0	-1.0 → Liquidacion + Finiquito sin SoftDeletes (documentos legales)
Tests backend	7.0	7.0	Sin variación — ambas coinciden en brechas RRHH/Contabilidad
Frontend / arquitectura	7.0	7.0	Sin variación — auditoría anterior cubrió bien este módulo
Tests frontend	6.0	6.0	Sin variación — 0 tests en Inventario/Clientes/Admin/Tributario
CI/CD y DevOps	6.0	6.0	Sin variación — sin staging, sin rollback, E2E fuera del pipeline
Cumplimiento normativo (nuevo)	N/D	4.5	LRE, DJ 1887, Art.58 CT, Ley 21.735 gradual, RCV — no cubiertos
Documentación	5.0	5.0	Sin variación — sin ADRs, runbooks ni ER diagram
PUNTUACIÓN GLOBAL	7.1	6.3	Corrección por bugs de seguridad no detectados + brechas normativas

1.2 Fortalezas confirmadas por ambas auditorías

- EmpresaScope aplicado en 56 modelos — multitenancy sólido (56 modelos verificados, 38 tablas catálogo correctamente excluidas)
- HMAC SHA-256 inter-servicio con ventana anti-replay 300s, nonce 128-bit y hash_equals() — implementación robusta
- RBAC declarativo en dos capas (middleware + controller) con 75 módulos y 200+ permisos

- Módulo SII bien probado: 87 tests, arquitectura de folios CAF con lock atómico y marcado HUERFANO elegante
- Módulo RRHH: cálculo de liquidaciones legalmente preciso (AFP por entidad, AFC con corte 11 años, ISAPRE/FONASA, APV)
- Frontend: lazy loading en 38 rutas, token refresh automático, multi-tab sync de logout
- CipherSweet implementado para PII cifrada en empleados — cumple Ley 21.719

1.3 Riesgos activos priorizados

- P0 — IDOR en auditoría de facturas: cualquier usuario puede leer trazabilidad de otro tenant (FacturaService.php, sin empresa_id filter)
- P0 — Mass assignment en actualizarCentro: \$request->all() sin whitelist expone campos sensibles
- P0 — SSO bypass: tokenLogin omite check de suscripción expirada — usuarios sin plan activo acceden al ERP completo
- P0 — SoftDeletes ausentes en Liquidacion.php y Finiquito.php — documentos laborales con borrado físico posible
- P1 — PPM hardcodeada al 1% — F29 tributariamente incorrecto para la mayoría de actividades
- P1 — Tope 45% Art. 58 CT no validado — sistema puede emitir liquidaciones ilegales
- P1 — Sin staging: cualquier bug post-merge llega inmediatamente a todos los tenants

2. Backlog consolidado y priorizado

Los ítems están ordenados por impacto regulatorio/legal primero, luego seguridad, luego estabilidad operacional. Los de P0 deben resolverse antes de cualquier nuevo desarrollo funcional.

Prio	Ítem	Origen	Área	Impacto si no se resuelve
P0	SoftDeletes en Liquidacion.php y Finiquito.php	Auditoría A	Backend / Legal	Borrado físico de documentos laborales — infracción DT
P0	IDOR en FacturaService::obtenerAuditoriaCompleta	Auditoría B	Seguridad	Cualquier usuario puede leer historial de facturas de otro tenant
P0	Mass assignment en EmpresaController::actualizarCentro	Auditoría B	Seguridad	Sobreescritura de campos sensibles (empresa_id, activo) vía API
P0	SSO tokenLogin: omite check subscription_status expired	Auditoría B	Seguridad / Negocio	Usuarios con plan vencido acceden al ERP completo vía SSO
P1	PPM hardcodeada 1% en ImpuestosService::simularF29	Auditoría B	Tributario	F29 incorrecto para la mayoría de actividades económicas
P1	Art.58 CT: tope 45% descuentos no validado en liquidaciones	Auditoría B	Legal / RRHH	Liquidaciones ilegales — multa DT + responsabilidad civil
P1	TODO P1 FacturaService:266 — período contable cerrado	Ambas	Backend / Contabilidad	Facturas en períodos cerrados corrompen el Mayor
P1	Staging environment — main va directo a prod	Auditoría A	DevOps	Un bug post-merge impacta todos los tenants simultáneamente
P1	CotizacionDetalle sin SoftDeletes — cascade incompleto	Auditoría B	Backend	Detalles huérfanos en BD al hacer soft-delete de cabecera
P2	LRE — Libro de Remuneraciones Electrónico (Res. SII N°94/2018)	Auditoría B	Legal / RRHH	Incumplimiento declarativo para clientes con ≥5 trabajadores
P2	DJ 1887 — Declaración Jurada retenciones 2ª Categoría	Auditoría B	Legal / RRHH	Infracción tributaria para empresas con impuesto único retenido
P2	Cronograma gradual Ley 21.735 (reforma previsional)	Auditoría B	Legal / RRHH	Cotización adicional no sube automáticamente por tramo anual

Prio	Ítem	Origen	Área	Impacto si no se resuelve
P2	Tests RRHH (9 tests para el módulo más complejo legalmente)	Ambas	Tests	Regresiones silenciosas en cálculo de liquidaciones
P2	Tests Inventario frontend (0 tests en 4.000+ líneas)	Auditoría A	Tests	Sin detección de regresiones en módulo más usado
P2	CSV injection en FacturaService::generarCsvExportacion	Auditoría B	Seguridad	Ejecución de fórmulas en Excel al abrir el export
P2	api.js: subscription_status de localStorage — spoofable	Auditoría A	Frontend / Seguridad	Cliente puede alterar estado de suscripción en browser
P3	contratoActivo sin filtro de fecha de término	Auditoría B	RRHH	Contratos vencidos generan liquidaciones
P3	E2E Playwright no corre en pipeline CI	Auditoría A	DevOps	Regresiones UI llegan a prod sin detección
P3	PHPStan nivel 5+ en backend	Auditoría A	Calidad	Bugs de tipos en producción
P3	IPC: sin validación de rango en variación mensual	Auditoría B	CorreccionMonetaria	Un typo (ej: 100 en vez de 1.0) corrompe todos los activos fijos
P3	Circuit breaker en llamadas HTTP al SII	Auditoría B	Resiliencia	SII caído satura todos los workers PHP
P3	/health endpoint público sin rate limiting	Auditoría B	Seguridad	Fingerprinting de infra + DoS sobre conexiones DB internas
P3	XMLs SII en storage local sin redundancia	Auditoría B	Compliance	Pérdida de XMLs requeridos legalmente por 6 años (Res. N°80)
P4	ARCO+: incluir historial de auditorías PII en exportación	Auditoría B	Privacidad / Legal	Portabilidad incompleta según Ley 21.719
P4	ADRs (Architecture Decision Records)	Auditoría A	Documentación	Sin trazabilidad de decisiones arquitectónicas
P4	Runbooks y disaster recovery	Auditoría A	Documentación	Sin procedimientos formales ante incidentes
P4	CA validation de certificados SII	Auditoría B	SII / Compliance	Sistema acepta PFX de cualquier CA, incluyendo no acreditadas
P4	Memoización MesaConciliacion + TomasFisicasInventario	Auditoría A	Frontend / Performance	Re-renders innecesarios en vistas de alta carga de datos

Prio	Ítem	Origen	Área	Impacto si no se resuelve
P4	Boletas de honorarios electrónicas (tipo DTE 39)	Auditoría B	Feature / SII	Gap funcional para clientes con prestadores a honorarios

3. Análisis diferencial entre auditorías

3.1 Lo que la Auditoría B encontró y A no cubrió

Estos hallazgos no estaban en la auditoría anterior y son exclusivos del análisis de código fuente profundo:

- IDOR en FacturaService::obtenerAuditoriaCompleta — Factura::findOrFail(\$id) sin empresa_id (bug crítico de seguridad)
- Mass assignment en EmpresaController::actualizarCentro — \$request->all() en lugar de validate()
- SSO tokenLogin: no verifica subscription_status==='expired' (bypass de monetización)
- PPM hardcodeada al 1% en simularF29 — error tributario material en el F29
- Tope 45% Art. 58 CT no implementado — riesgo legal laboral en liquidaciones
- IPC sin validación de rango — variación del 1000% no es rechazada
- CSV injection en generarCsvExportacion — fórmulas en campos de proveedor
- LRE obligatorio no implementado (Res. SII N°94/2018 para ≥5 trabajadores)
- DJ 1887 no generada — obligación tributaria para retenciones de impuesto único
- Cronograma Ley 21.735 no implementado — cotización adicional no sube por tramo anual
- contratoActivo sin filtro de fecha de término — contratos expirados generan liquidaciones
- CotizacionDetalle sin SoftDeletes — cascade incompleto al eliminar cotización
- Circuit breaker ausente en llamadas HTTP al SII
- ARCO+: historial de auditorías PII no incluido en exportación (Ley 21.719)
- CA validation ausente en carga de certificados SII

3.2 Lo que la Auditoría A encontró y B no enfatizó

Estos hallazgos son propios de la auditoría A y complementan el panorama:

- SoftDeletes faltantes en Liquidacion.php y Finiquito.php — documentos legales con borrado físico
- api.js L377-386: subscription_status leído de localStorage — spoofable desde el browser
- Sin staging environment — main va directo a producción multitenant
- E2E Playwright no corre en CI pipeline — regresiones UI sin detección automatizada
- Sin SAST (PHPStan/ Psalm/ESLint strict) — bugs de tipos en producción
- Sin threshold de cobertura en CI — tests pasan con 2% de coverage
- Sin rollback en deploy — un deploy roto requiere intervención manual SSH
- LOG_LEVEL=debug en .env.example — logs verbose en producción si no se sobrescribe
- SiiCatComunasSeeder: TODO de 346 comunas pendiente (datos de catálogo incompletos)
- ActivoFijoController.php (394L) y FacturaController.php (379L) candidatos a split
- MesaConciliacion.jsx: 36 useState + prop drilling profundo — candidato a refactor con Context
- 0 tests en Inventario frontend (4.000+ líneas), Clientes, Administrador, Tributario

4. Instrucciones de orquestador — sprints de implementación

Los siguientes prompts están diseñados para ser entregados a un ejecutor (otra instancia de Claude o un desarrollador) sin contexto adicional. Cada prompt incluye el alcance exacto, los archivos involucrados y los criterios de salida verificables. El orquestador no escribe código — entrega estas instrucciones y valida los resultados contra los criterios de salida.

4.1 Sprint P0 — Críticos de seguridad y legal (antes de próximo deploy)

[P0-SEC-01] Fix IDOR en obtenerAuditoriaCompleta

Contexto: FacturaService::obtenerAuditoriaCompleta(int \$id) en app/Domains/Comercial/Services/FacturaService.php ejecuta Factura::findOrFail(\$id) sin filtrar por empresa_id, exponiendo la auditoría de facturas de cualquier tenant a cualquier usuario. Tarea: 1. Reemplazar la línea: `$factura = Factura::with('proveedor')->findOrFail($id);` por: `$factura = Factura::where('empresa_id', $empresaId)->with('proveedor')->findOrFail($id);` asegurándote de que el método recibe \$empresaId como parámetro (ya lo recibe en la firma, solo no lo usaba en este query). 2. Verificar que el endpoint que llama a este método en FacturaController pasa \$request->user()->empresa_id correctamente. 3. Agregar test en tests/Feature/Comercial/: `test_no_puede_ver_auditoria_de_factura_de_otra_empresa()` que autentica como user de empresa A e intenta obtener la auditoría de una factura de empresa B con id conocido, esperando 404. Criterio de salida: el test nuevo pasa, suite completa verde.

[P0-SEC-02] Fix mass assignment en actualizarCentro

Contexto: EmpresaController::actualizarCentro() en app/Domains/Core/Controllers/EmpresaController.php llama \$this->empresaService->actualizarCentroCosto(\$request->user()->empresa_id, \$id, \$request->all()) pasando \$request->all() sin whitelist — cualquier campo del body es aceptado (empresa_id, activo, etc.). Tarea: 1. Reemplazar la llamada por: `$datos = $request->validate(['codigo' => 'sometimes|string|max:20', 'nombre' => 'sometimes|string|max:100',]);` `$centro = $this->empresaService->actualizarCentroCosto($request->user()->empresa_id, $id, $datos);` 2. Asegurarse de que EmpresaService::actualizarCentroCosto solo persiste los campos recibidos (update(\$datos), no \$request->all()). Criterio de salida: suite verde; intento de PATCH con {empresa_id:999} en body no modifica el empresa_id del centro.

[P0-SEC-03] Fix SSO tokenLogin: agregar check subscription_status expired

Contexto: AuthController::tokenLogin() en app/Domains/Core/Controllers/AuthController.php NO verifica \$user->subscription_status === 'expired', a diferencia del flujo login() que sí lo hace (línea ~75). Un usuario con suscripción vencida puede entrar al ERP completo vía SSO desde tenri.cl. Tarea: Después del bloque que verifica estadoSuscripcion->nombre !== 'Activa', agregar (copiando el mismo patrón del método login()): `if ($user->subscription_status === 'expired') { return response()->json(['success' => false, 'message' => 'Tu suscripción venció. Renueva tu plan en tenri.cl.', ], 403); }` Asegurarse de que el orden de guards sea idéntico al de login(): 1. estadoSuscripcion !== 'Activa' 2. empresa activa 3. bloqueado_hasta 4. subscription_status === 'expired' Criterio de salida: test que provisiona un user con subscription_status='expired' y llama tokenLogin — espera 403.

[P0-LEGAL-01] Agregar SoftDeletes en Liquidacion y Finiquito

Contexto: Liquidacion.php y Finiquito.php en app/Domains/Rrhh/Models/ no tienen SoftDeletes. Son documentos legales laborales — el borrado físico es infracción a la obligación de conservación de registros (6 años). Tarea: 1. Crear migración: php

artisan make:migration add_soft_deletes_to_liquidaciones_finiquitos_table Con:
Schema::table('liquidaciones', fn(\$t) => \$t->softDeletes());
Schema::table('finiquitos', fn(\$t) => \$t->softDeletes()); 2. Agregar use SoftDeletes;
en Liquidacion.php y Finiquito.php. 3. Revisar que los tests existentes de RRHH (9
tests) sigan verdes – ninguno debe usar delete() directo sobre estos modelos. 4.
En LiquidacionService::anular() verificar que la anulación sigue usando \$liq-
>update(['estado'=>'ANULADA']) y NO \$liq->delete(), porque anular no es lo mismo
que borrar. Criterio de salida: migración aplicada, modelos con SoftDeletes, suite
completa verde.

4.2 Sprint P1 — Alta prioridad (próximas 2 semanas)

[P1-TRIB-01] Corregir PPM hardcodeada en F29

Contexto: ImpuestosService::simularF29() en
app/Domains/Contabilidad/Services/ImpuestosService.php tiene \$tasaPpm = 1.00;
hardcodeada. La tasa PPM varía por actividad económica (0,2% – 5% según Art. 84 LIR) y
puede incluso ser 0 para algunos rubros. Tarea: 1. Agregar campo ppm_pct (decimal
5,2, default 1.00) a la tabla empresas (nueva migración). 2. Exponerlo en
EmpresaController::actualizarPerfil con la validación: 'ppm_pct' =>
'nullable|numeric|min:0|max:10'. 3. En simularF29(), reemplazar la línea hardcodeada
por: \$empresa = DB::table('empresas')->where('id',\$empresaId)->first(); \$tasaPpm
= (float)(\$empresa->ppm_pct ?? 1.00); 4. Actualizar la vista de perfil de empresa en
el frontend para mostrar y editar el campo PPM (%). Criterio de salida: empresa
con ppm_pct=0.3 genera F29 con PPM correcto; empresa sin campo usa 1.0 por defecto.

[P1-LEGAL-02] Implementar tope Art. 58 CT en liquidaciones

Contexto: LiquidacionService::calcular() en
app/Domains/Rrhh/Services/Calculo/LiquidacionService.php calcula \$totalDescuentos sin
verificar que no supere el 45% del total de haberes (Art. 58 Código del Trabajo).
Adicionalmente, los descuentos voluntarios no pueden superar el 15% individualmente.
Tarea: 1. Después de calcular \$totalDescuentos, antes de \$liquidoPagar: // Tope
Art.58 inciso 2: descuentos voluntarios <= 15% \$topeDesc15Pct =
round(\$totalImponible * 0.15); if (\$totalDescuentosVoluntarios > \$topeDesc15Pct) {
throw RrhhException::regla("Los descuentos voluntarios
({\$totalDescuentosVoluntarios}) superan el límite legal del 15% del imponible
({\$topeDesc15Pct}). Art. 58 CT."); } // Tope Art.58 inciso 1: total
descuentos <= 45% \$topeTotal = round((\$totalImponible + \$totalNoImponible) * 0.45);
if (\$totalDescuentos > \$topeTotal) { throw RrhhException::regla("Los
descuentos totales ({\$totalDescuentos}) superan el 45% del total de haberes
({\$topeTotal}). Art. 58 CT."); } 2. Agregar tests en tests/Feature/Rrhh/:
- test_lanza_excepcion_cuando_descuentos_voluntarios_superan_15pct() -
test_lanza_excepcion_cuando_total_descuentos_supera_45pct() Criterio de salida: ambos
tests pasan; suite completa verde.

[P1-CONT-01] Resolver TODO P1 — bloqueo período contable en reclasificación

Contexto: FacturaService::reclasificarAsiento() en
app/Domains/Comercial/Services/FacturaService.php línea ~266 tiene el comentario: //
TODO (P1): agregar bloqueo de periodo contable cerrado // sobre \$datos['fecha'] El
período de la fecha de destino no es validado, permitiendo reclasificar asientos hacia
fechas en períodos cerrados. Tarea: Después de las dos llamadas \$periodos-
>assertAbierto() existentes, agregar validación sobre \$datos['fecha']: \$periodos-
>assertAbierto(\$empresaId, \$datos['fecha']); Verificar que
PeriodoContableService::assertAbierto() lanza PeriodoCerradoException cuando el
período está cerrado y que el catch del controller lo convierte en 422. Remover el
comentario TODO una vez implementado. Criterio de salida: test que intenta
reclasificar hacia período cerrado recibe 422; suite completa verde.

[P1-DEVOPS-01] Crear staging environment en CI/CD

Contexto: el pipeline .github/workflows/ci-cd.yml despliega directamente a producción
en push a main sin environment intermedio. Un bug post-merge impacta todos los tenants

simultáneamente. Tarea: 1. Crear branch 'staging' protegida en GitHub. Configurar GitHub Environment 'staging' con URL `https://staging.erp.tenri.cl`. 2. En `ci-cd.yml`, agregar job 'deploy-staging' que se ejecuta en push a 'staging' (NO a main), usando las variables de entorno del environment 'staging' en DirectAdmin. 3. El job 'deploy-prod' solo corre en push a main Y después de que el job de deploy-staging haya pasado en las últimas 24h (usar needs + condicional o aprobación manual de environment). 4. Definir las variables de entorno de staging en GitHub Secrets (DB_DATABASE_STAGING, APP_KEY_STAGING, etc.) separadas de prod. Criterio de salida: push a staging despliega a `staging.erp.tenri.cl` sin afectar producción; push a main requiere aprobación o staging sano.

4.3 Sprint P2 — Normativo y cobertura de tests

[P2-LRE-01] Implementar LRE — Libro de Remuneraciones Electrónico

Contexto: La Res. SII Exenta N°94/2018 exige el envío mensual del LRE al SII para empresas con 5+ trabajadores. El módulo RRHH calcula liquidaciones pero no tiene módulo de exportación LRE. Tarea: 1. Crear `app/Domains/Rrhh/Services/LreService.php` con método: `generarLre(int $empresaId, int $anio, int $mes): array` que retorna el formato XML según Res. N°94/2018 (ver `docs/rrhh-leyes/` para estructura). 2. Crear `tests/Feature/Rrhh/LreTest.php` con: `- test_genera_lre_con_formato_correcto()` `- test_incluye_solo_liquidaciones_emitidas_del_periodo()` `- test_genera_totales_correctos_por_concepto()` 3. Crear endpoint POST `/api/rrhh/lre/generar` en `routes/api.php` con middleware `permiso:rrhh.gestionar`. 4. Documentar en `README.md` el proceso de envío manual al SII hasta que se implemente el envío automático. Criterio de salida: endpoint retorna XML válido según schema LRE, tests pasan, suite completa verde.

[P2-CM-01] Agregar validación de rango IPC en `CorreccionMonetariaService`

Contexto: `CorreccionMonetariaService::guardarIndice()` acepta cualquier float para `$variacion`. Un error de tipo (ej: 100 en vez de 1.0) actualizaría todos los activos fijos por factor `*11`. Tarea: Al inicio del método `guardarIndice()`, después de las validaciones de mes/año, agregar: `if ($variacion < -30.0 || $variacion > 30.0) { throw new Exception("La variación IPC mensual ({ $variacion}%) está fuera del rango aceptable (-30% a +30%). Verifique el valor ingresado."); }` Agregar test: `test_rechaza_variacion_ipc_fuera_de_rango()` Criterio de salida: test pasa, `guardarIndice` con `variacion=100` lanza `Exception`, suite completa verde.

[P2-TEST-01] Ampliar cobertura de tests RRHH

Contexto: el módulo RRHH tiene 9 tests para la lógica más compleja legalmente del sistema. Los casos edge más críticos no están cubiertos. Tarea: crear en `tests/Feature/Rrhh/` los siguientes tests: 1. `LiquidacionCalculoTest.php`: `- test_calcula_gratificacion_con_tope_imm_correcto()` `- test_calcula_impuesto_unico_con_tabla_vigente()` `- test_descuenta_afc_solo_hasta_11_anios_contratos_indefinidos()` `- test_isapre_adicional_no_rebaja_base_tributable()` `- test_lanza_excepcion_sin_parametros_previsionales()` `- test_lanza_excepcion_sin_indicadores_mensuales()` `- test_no_recalcula_liquidacion_emitida()` 2. `FiniquitoTest.php`: `- test_calcula_vacaciones_proporcionales_correctamente()` `- test_no_permite_finiquito_sin_contrato_activo()` 3. `PreviredTest.php`: `- test_genera_formato_previred_con_estructura_correcta()` Cada test debe crear los fixtures necesarios (empresa, empleado, contrato, parametros, indicadores) usando factories o el patrón existente en los 9 tests actuales. Criterio de salida: mínimo 20 tests RRHH, todos verdes.

4.4 Sprint P3 — Deuda técnica y resiliencia

[P3-RRHH-01] Agregar filtro de fecha a `contratoActivo` en `Empleado`

Contexto: la relación contratoActivo en app/Domains/Rrhh/Models/Empleado.php devuelve contratos donde activo=true sin verificar que fecha_termino sea futura. Contratos a plazo fijo vencidos y no actualizados generan liquidaciones. Tarea: 1. Localizar la definición de contratoActivo() en Empleado.php. 2. Agregar al scope: ->where(function(\$q) { \$q->whereNull('fecha_termino') ->orWhere('fecha_termino', '>=', now()->toDateString()); }) 3. Agregar test: test_contrato_expirado_no_aparece_como_activo() Criterio de salida: test pasa, empleado con contrato de fecha_termino ayer no genera liquidación, suite verde.

[P3-SII-01] Agregar circuit breaker / timeout en llamadas HTTP al SII

Contexto: PollerEstadoSiiService y SiiUploadService en app/Domains/Sii/Services/ hacen HTTP requests al SII sin timeout explícito ni circuit breaker. SII caído satura workers. Tarea: 1. En cada cliente HTTP hacia el SII, asegurarse de que el cliente Guzzle o Http facade tenga: ->timeout(30) // segundos máximos de espera ->connectTimeout(10) 2. Envolver las llamadas de polling en try/catch con: catch (\Illuminate\Http\Client\ConnectionException \$e) { Log::channel('sii')->warning('SII no disponible', [...]); // Dejar DTE en estado actual, reintentar en siguiente job return; } 3. Agregar campo 'intentos_polling' (integer, default 0) al modelo SiiDteEmitido si no existe, e incrementarlo en cada intento fallido. Desactivar polling automático si supera 48 intentos. Criterio de salida: test con mock de timeout no lanza Uncaught Exception, el DTE queda en su estado previo, suite verde.

[P3-MODEL-01] CotizacionDetalle: agregar SoftDeletes para cascade correcto

Contexto: Cotizacion tiene SoftDeletes pero CotizacionDetalle no. Al hacer soft-delete de una cotización, sus detalles quedan físicamente en BD pero sin relación lógica al cabecera eliminada. Tarea: 1. Migración: Schema::table('cotizacion_detalle', fn(\$t) => \$t->softDeletes()); 2. use SoftDeletes; en CotizacionDetalle.php. 3. En CotizacionService (o Observer), al hacer soft-delete de Cotizacion, ejecutar: \$cotizacion->detalles()->delete(); // soft-delete en cascade 4. Verificar que los tests de Cotizacion sigan verdes. Criterio de salida: soft-delete de cotización soft-deletes sus detalles, suite completa verde.

5. Deuda técnica frontend — instrucciones de sprint

[P2-FE-01] Fix: subscription_status de localStorage spoofable

Contexto: `src/Configuracion/api.js` L377-386 lee `subscription_status` de `localStorage` para tomar decisiones de UI. Un usuario puede modificar este valor en DevTools y ver rutas que no debería ver (la protección real está en el backend, pero la UI da información errónea). Tarea: 1. Mover `subscription_status` al `AuthContext`, cargado únicamente del endpoint `GET /api/auth/me` (que lo extrae del token/DB, no del input del usuario). 2. Eliminar las referencias a `localStorage.getItem('subscription_status')`. 3. El `AuthContext` ya tiene el patrón correcto para otros campos — seguir el mismo patrón. Nota: el backend siempre debe ser la fuente de verdad. Este fix es para evitar confusión en la UI, no para el modelo de seguridad. Criterio de salida: manipular `localStorage` no cambia las rutas visibles; los datos vienen del `/me` endpoint.

[P4-FE-01] Refactor MesaConciliacion: reducir 36 useState con Context

Contexto: `src/Modulos/Banco/Vistas/MesaConciliacion.jsx` tiene 36 `useState` y prop drilling profundo (642 líneas). Re-renders innecesarios afectan performance en mesas con muchos movimientos. Tarea: 1. Identificar los grupos lógicos de estado (filtros, selección, proceso de conciliación, resultados) — probablemente 3-4 grupos. 2. Crear `src/Modulos/Banco/Context/ConciliacionContext.jsx` con `useReducer` para el estado complejo de la conciliación. 3. Migrar los 36 `useState` al Context progresivamente, empezando por los que causan más prop drilling. 4. Agregar `React.memo()` en los subcomponentes que reciben props estables (tablas de movimientos, panel de resumen). 5. Mantener funcionalidad existente — no cambiar comportamiento. Criterio de salida: tests de Banco siguen verdes (si existen), render count en DevTools Profiler se reduce al menos 30%.

[P2-FE-02] Agregar mínimo 20 tests a módulos Inventario frontend

Contexto: `src/Modulos/Inventario/` tiene 4.000+ líneas y 0 tests. Es uno de los módulos más usados del ERP. Tarea: crear en `src/Modulos/Inventario/__tests__/` o equivalente: 1. `ProductoList.test.jsx`: - renderiza lista de productos correctamente - filtra por nombre - muestra badge de stock crítico cuando `stock < minimo` 2. `MovimientoForm.test.jsx`: - valida que tipo de movimiento sea requerido - muestra error si `cantidad <= 0` - llama al `api.js` con los datos correctos al submit 3. `TomaFisica.test.jsx`: - renderiza ítems de la toma física - permite marcar ítem como contado - bloquea confirmar si hay ítems sin contar Usar el patrón de los tests existentes en `src/Modulos/Rrhh/`. Mockear `api.js` con `jest.mock('.././../Configuracion/api')`. Criterio de salida: mínimo 20 tests en módulo Inventario, todos verdes.

6. Brechas normativas — roadmap de alcance

Los siguientes ítems representan funcionalidad normativa que el ERP necesita para cumplir plenamente la legislación chilena. No son bugs sino features faltantes con impacto regulatorio. Se recomienda tratarlos como épicas separadas en el roadmap, con cada una incluyendo la investigación normativa, el diseño técnico y los tests de aceptación.

Brecha normativa	Marco legal	Urgencia	Descripción del alcance técnico
LRE (Libro Remuneraciones Electrónico)	Res. SII N°94/2018	Alta	Generación y envío XML mensual para empresas ≥5 trabajadores
DJ 1887 — Retenciones 2ª Categoría	LIR Art. 42-43	Alta	Generación del archivo DJ 1887 anual con datos por trabajador
Registro de Compras y Ventas (RCV)	Res. SII DTE	Alta	Módulo de envío mensual del RCV al portal SII
Ley 21.735 — Cronograma cotización adicional	Ley 21.735	Alta	Tabla de tasas por año hasta 2028; ajuste automático según fecha período
Boletas de honorarios (tipo DTE 39)	Res. SII DTE	Media	Flujo propio: retención 13.75%, formato XML tipo 39, envío al SII
Propyme H17/H18: PPM diferenciado y límite UF	LIR Art. 14 y 84	Media	Tasa PPM Propyme, validación límite 75.000 UF anuales
CA validation certificados SII	Res. SII firma electrónica	Baja	Validar issuerCn contra lista de CAs acreditadas ante el SII
ARCO+ historial de accesos PII en portabilidad	Ley 21.719	Baja	Incluir tabla auditorías (LECTURA) en el paquete de exportación ARCO

Nota: las brechas de urgencia Alta deben estar en el roadmap para el próximo trimestre. Las de urgencia Media para el segundo semestre 2026. Las de urgencia Baja pueden planificarse como improvements del sistema.

7. Protocolo de orquestación

7.1 Rol del orquestador

El orquestador NO escribe código. Su función es:

- Entregar los prompts de este documento al ejecutor (otra instancia de Claude o desarrollador)
- Validar los criterios de salida de cada sprint antes de aprobar el merge
- Mantener el backlog actualizado conforme se cierran ítems
- Escalar al equipo cuando un ítem tenga dependencias no documentadas aquí

7.2 Secuencia de sprints recomendada

- Sprint 1 (urgente): P0-SEC-01, P0-SEC-02, P0-SEC-03, P0-LEGAL-01 — paralelos, sin dependencias cruzadas
- Sprint 2: P1-TRIB-01, P1-LEGAL-02, P1-CONT-01 — bloquear deploy hasta tener staging (P1-DEVOPS-01)
- Sprint 3: P2-LRE-01, P2-TEST-01, P2-FE-01, P2-FE-02, P2-CM-01
- Sprint 4: P3-RRHH-01, P3-SII-01, P3-MODEL-01, P4-FE-01

7.3 Criterio de calidad mínimo para cada PR

- Suite completa verde (229 tests + nuevos tests del ítem)
- Sin regresiones: diff de coverage no baja respecto al baseline
- El ítem referenciado en este backlog queda cerrado con número de commit
- Si el ítem tiene criterio de salida documentado en este informe, el orquestador lo valida antes del merge

— Fin del informe —